



Mythos is a powerful general-purpose LLM that shows strong cyber security capabilities

What is Mythos?

- A general-purpose LLM that demonstrates high-level reasoning across various domains
- Model performs strongly across the board, but is strikingly capable at cyber security tasks
- Highest class of models from Anthropic, followed by Opus, Sonnet, Haiku

What was demonstrated

Evaluations showed it capable of:

- Autonomous vulnerability discovery: scanning and identifying exploitable flaws in real-world systems without human input
- Exploit generation in hours: writing working exploit code from scratch, a task that previously required days of specialist effort
- Spear-phishing at scale: crafting contextually accurate, personalised lures
- Multi-stage attack chaining: linking reconnaissance, initial access, lateral movement and data exfiltration autonomously

Reports suggest that Mythos works best with **white-box testing** (i.e. with source code access). Evidence of its effectiveness on closed-source systems remains limited.

Frontier AI capabilities are being weaponized across the kill chain – Mythos is a trend, not a one-off

Reconnaissance

Frontier AI models were able to discovery vulnerabilities at unprecedented speed and scale.

- **AI assisted vulnerability research uncovered 38 security vulnerabilities in OpenEMR**, an open-source electronic health records platform. They include authentication bypass and privilege escalation flaws identified through automated code analysis workflows
- **Mozilla disclosed that AI assisted vulnerability research helped identify hundreds of previously unknown security weaknesses** in the Firefox browser engine, accelerating large scale code auditing and patch development
- **Security researchers observed that AI assisted bug hunting dramatically accelerated vulnerability discovery in open-source ecosystems.** For example, almost every Linux distribution recently found itself on the wrong end of the Copy Fail and Dirty Frag privilege escalation vulnerabilities (gaining administrator access with a local account), for which patches hadn't been made widely available as there wasn't enough time between their disclosure and publication.

Weaponisation and beyond...

Frontier AI models were able to generate exploits at speed and with little human intervention

- **Critical security flaws are observed to be exploited within hours:**
 - Flaw in BerriAI's LiteLLM Python package has come under active exploitation in the wild within 36 hours of the bug becoming public knowledge
 - Flaw in LMDeploy, an open-source toolkit for compressing, deploying, and serving LLMs, has come under active exploitation in the wild less than 13 hours after its public disclosure.
 - Flaw in PraisonAI, an open-source multi-agent orchestration framework, found to be exploited within 4 hours of public disclosure.
- **Google's latest Threat Intelligence report identified the first AI-generated zero-day exploit used in a real-world cybercrime operation.** The exploit, designed to bypass two-factor authentication in a widely used open-source administration tool, reportedly showed characteristics consistent with AI-generated code, including hallucinated CVSS scoring, structured textbook-style formatting, and AI-assisted reasoning around logic flaws.

This is not just an IT problem, but will affect OT

The end of security by obscurity

AI can read the manuals — and reason

- Vendors' product documentation, protocol specs, and maintenance guides are public
- AI ingests these and derives attack paths without needing prior hands-on access to the hardware
- Proprietary protocols and specialist knowledge are no longer a barrier to entry.

What this means in practice

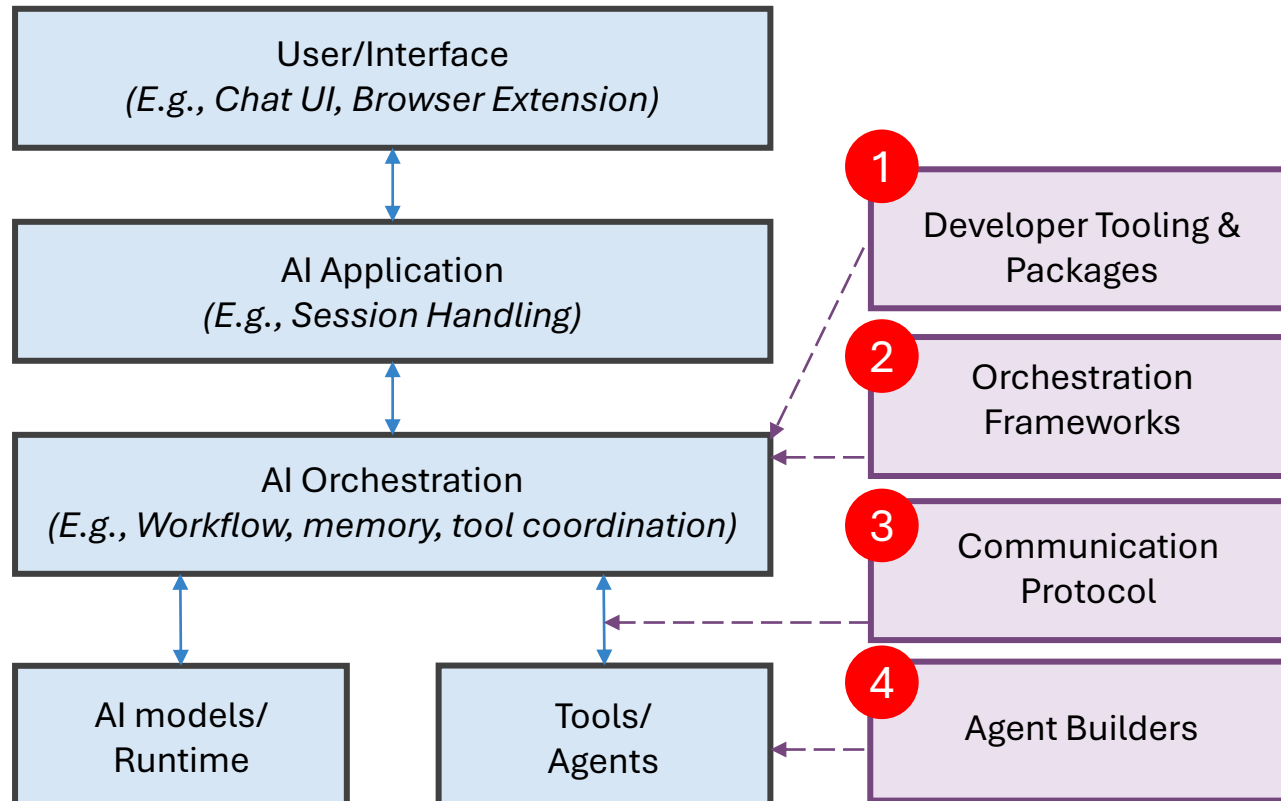
1. A threat actor no longer needs field experience with a Siemens PLC or Schneider SCADA system — AI provides that knowledge on demand.
2. Systems that were assumed to be safe because attackers 'wouldn't know how they worked' must now be assessed as if that knowledge is freely available.
3. Many OT protocols (e.g. Modbus, DNP3, IEC 61850, PROFINET) are documented in specifications that AI can ingest. Protocol obscurity is not a control.

So what

- Expect OT attacks to become more accessible, scalable and frequent over time. Dragos reported that an adversary had leveraged AI to compromise a water plant's OT in Monterrey, Mexico
- Significant further work will be needed across Government and CII sectors

AI security issues continue to grow across different components – implications will be significant with growing adoption

Supply chain is a big issue. Beyond model and tools, attackers are also targeting AI developer tooling and packages, orchestration frameworks, agent builders, etc.



1 Vulnerabilities found in LiteLLM could allow attackers to steal credentials, move laterally across Kubernetes environments, and establish persistent backdoors through compromised AI package dependencies used in enterprise AI stacks.

2 Vulnerabilities found in LangChain and LangGraph could allow attackers to access filesystem contents, environment secrets, and conversation history by abusing weaknesses in the orchestration layer connecting models to enterprise data and tools.

3 Vulnerabilities found in MCP's STDIO transport protocol could result in arbitrary OS command execution across downstream SDKs, MCP servers, and agent implementations, creating a broad supply-chain risk across the AI tooling ecosystem.

4 Vulnerabilities found in Langflow and Flowise could allow attackers to perform remote code execution and compromise internet-facing AI agent platforms used to build and operate agentic workflows.

Immediate actions

We need to make immediate operational and technical interventions for secure development, access, configuration, assurance, visibility and response

- **Immediately, we must tighten cyber hygiene and build stronger capabilities for secure development, access, configuration, assurance and visibility & response [focus of this deck]**
 - Cyber hygiene is a longstanding best practice, but the rapid proliferation of AI-enabled attack tools has raised the baseline threat significantly
 - Foundational hygiene not as a compliance exercise but as a dynamic, continuously enforced discipline
- To complement these, we will also need to leverage and adjust our ecosystem of tools, partners and shared threat intelligence
 - Some broader structural reforms — including workforce reskilling and cross-agency governance — will slow down our immediate response if taken together; we will return with fuller recommendations on these at a later date
- In the longer term, we will need to review our policy positions and CONOPS with further/more significant step changes in AI-enabled cybersecurity capability, — in particular, the emergence of autonomous offensive operations that require no persistent human direction
 - This needs to be incorporated into reviews of the NCDD and CSA's own operational CONOPS, specifically to address over-reliance on operator expertise and human-in-the-loop workflows that will be too slow to counter machine-speed attacks

RESTRICTED

We have identified five action pillars to shore up defences immediately

Focus of today's discussion

Immediate actions

What should defenders do differently to address AI-enabled threats?

1. Secure Access

Control who gets in and under what conditions

2. Secure Configuration

Ensure systems are properly set up and hardened, and vulnerabilities are managed

3. Security Assurance

Verify controls are working in practice

4. Secure Development

Build security into how new technology is developed and deployed.

5. Visibility and response

Expand and speed up threat detection and incident response

Completed/Upcoming initiatives

For CIIOs

- CCOP as a baseline
- NCSC alert
- CIIO strategy
- Ops Overlord + “get better” plan

For WoG

- IM8 as a baseline
- GovTech advisory
- Cyber Hygiene Campaign
- Ops Diamond Bastion

For rest of ecosystem

- SingCERT advisory

What else do we need to do?

Standards

Tools

Capabilities

International

R&D

Industry development

etc...

Immediate actions: Questions for discussion [slides 9-14]

1. Prioritisation of actions

- a. Do we agree that these are the right actions to focus on? Are there threats, gaps or actions that aren't reflected here that we think should be?
- b. Are the actions currently practical and feasible — or are some aspirational in ways we should be upfront about?
- c. How do the actions on the slides map to what's already underway (e.g. Ops Overlord)? Can we fold them in to existing initiatives, and where are the gaps?

2. Implementation of actions

- a. For each control identified, are we purely issuing guidance, or are there operational/testing etc. activities running alongside them?
- b. How confident are we in the assurance picture we are getting from CIIOs' self-reports? What are the blind spots? What would a more robust verification or testing capability look like?
- c. Where should CSA play a more active role in helping sectors implement controls — for example, through automation tooling, reference architectures, or recommended configurations?

3. Capability

- a. What capabilities do we need to start building immediately to implement these actions?
- b. Are we already starting to build these capabilities, and where are the gaps we need to pay more attention to?

[Pillar 1] Secure Access: Control who gets in and under what conditions

Why this matters with AI	Delta from traditional practice	Specific Actions [Lead divisions]
AI-enhanced phishing attacks are expected to overpower traditional defenses (e.g. awareness/ education campaigns), as AI is rapidly improving the quality, volume and contextualization of phishing lures. More convincing credential-theft attempts are now achievable by a broader range of actors, with or without technical expertise.	Implement phishing-resistant authentication methods for all high-risk accounts, e.g. FIDO2/hardware-token MFA. Systems that are unable to support FIDO-based authentication should implement brute-force countermeasures for OTPs, such as rate limiting and restricting the number of OTP entry attempts permitted before logout.	<u>CSA/Govtech</u> • [NCTIC/CSG] Issue alerts/advisories to require CIIOs and govt agencies to implement these controls [completed] • [CIID] Update CCoP requirements • [CSG] Cyber Hygiene Campaign [ongoing] <u>Sector leads</u> • Develop sector-specific implementation guides (e.g. specific MFA methods and compensating controls such as IP allowlisting) <u>CIIOs</u> • Deploy required controls

[Pillar 2] Secure Configuration: Ensure systems are properly set up and hardened, and vulnerabilities are managed

Why this matters with AI	Delta from traditional practice	Specific Actions [Lead divisions]
AI is expected to significantly compress the time between vulnerability disclosure and active exploitation, especially for edge devices and internet-facing systems. Traditional patching cycles may no longer be able to keep up.	Patching: Require hard patching deadlines especially for critical internet-facing assets. Implement automated patch deployment where feasible. Perimeter hardening: Reduce internet-facing exposure by removing or restricting internet-facing services that are not operationally required, and removing direct internet exposure from administrative interfaces and management planes. Segmentation: Strengthen segmentation across different network zones (including OT/IT segmentation, micro-segmentation), to contain AI-driven movement to limit “blast radius”.	<u>CSA/Govtech</u> • [NCTIC/CSG] Issue alerts/advisories to require CIIOs and govt agencies to implement these controls [completed] • [CIID] Update CCoP requirements • [CSG] Cyber Hygiene Campaign [ongoing] <u>Sector leads</u> • Develop sector-specific implementation guides (e.g. specific methods or compensating controls) <u>CIIOs</u> • Deploy required controls

[Pillar 3] Security Assurance: Verify controls are working in practice

Why this matters with AI	Delta from traditional practice	Specific Actions [Lead divisions]
AI-assisted reconnaissance may enable attackers to rapidly discover assets, exposures and vulnerabilities. Periodic, manual penetration testing alone cannot keep pace with continuous AI-driven discovery. Defenders need to shift from periodic to continuous vulnerability management and security testing.	Live inventory: Maintain a live inventory of all critical systems, including unsupported assets, third-party connections, and cloud-hosted or provider-owned components. Build up VulnOps capabilities across the ecosystem to enable continuous autonomous vulnerability discovery and remediation	<u>CSA</u> • [NCTIC/CSG] Issue alerts/advisories to require CIIOs and govt agencies to implement these controls <i>[completed]</i> • [CIID] Update CCoP requirements • [CSEC / CSG] Adopt/procure AI-enabled VulnOps solutions (e.g. XBOW), and support CIIOs' adoption • [CSG] Cyber Hygiene Campaign <i>[ongoing]</i> <u>Sector leads</u> • Develop sector-specific implementation guides <u>CIIOs</u> • Deploy required controls

[Pillar 4] Secure Development: Build security into how new technology is developed and deployed.

Why this matters with AI	Delta from traditional practice	Specific Actions [Lead divisions]
Frontier AI models demonstrate the capability to surface latent software defects at scale across critical codebases. Vulnerabilities now carry a materially higher risk than previous assessments reflected.	Secure coding practices: Apply mandatory assurance gates to all production changes in internet-facing critical systems. Gates should include peer review, dependency inventory, secrets scanning, and security testing. Update threat models and risk assessments: perform and review threat models and risk assessments to account for heightened AI risks (e.g. increased discoverability and exploitability of vulnerabilities)	<u>CSA</u> • [NCTIC] Issue alert to require CIIOs to implement controls [completed] • [CIID] Update CCoP requirements • [CSEC/CSG] Adopt/procure AI-enabled DevSecOps / code scanning solutions, and support CIIOs' adoption <u>GovTech</u> • Cyber Hygiene Campaign [ongoing] <u>Sector leads</u> • Develop sector-specific implementation guides <u>CIIOs</u> • Update threat models and risk assessments • Deploy additional secure coding controls

[Pillar 5] Visibility and Response: Speed up threat detection and response (1/2)

Why this matters with AI	Delta from traditional practice	Specific Actions [Lead divisions]
AI-accelerated attack chains are rapidly compressing incident response and decision time for defenders. In an AI-accelerated threat environment, delayed exposure confirmation is operationally equivalent to having no early warning capability.	Harness AI vulnerability detection and patching tools including frontier AI models (e.g. Mythos), and other tools (e.g. Google CodeMender) Continuous vulnerability scanning (via ASM), to actively track and monitor vulnerabilities Strengthen threat detection and hunting to detect suspicious threat activities	<u>CSA / GovTech</u> • [NCIRC] Establish automated threat hunting capabilities in CIIOs as a baseline, and implement regular deep dive threat hunts for selected Tier 1 CIIOs (Telco & Power) <i>[ongoing – Ops OVERLORD]</i> • [CMO] Equip CIIOs with proprietary, advanced sensors (NEMOS) <i>[ongoing – Ops OVERLORD]</i> • [CSG/ TBD?] Put in place “national shield” capabilities such as protective DNS and central WAF for govt systems and CIIOs <i>[TBC e.g. Ops Diamond Bastion for WoG]</i> • [CSEC/CSG] Adopt/procure AI-enabled vulnerability detection and patching solutions, and support CIIOs’ adoption. • Establish a national Glasswing-equivalent early warning programme, by negotiating early access agreements to frontier AI tools, and leveraging our knowledge of CIIOs’ external attack surface to provide tailored guidance <u>Sector Leads</u> • Work with CSA/ GovTech to build CIIOs’ threat detection and response capabilities <u>CIIOs</u> • Deploy canaries and honey tokens throughout the network to detect attacks independent of vulnerability type.

[Pillar 5] Visibility and Response: Speed up threat detection and response (2/2)

Why this matters with AI	Delta from traditional practice	Specific Actions [Lead divisions]
AI-accelerated attack chains are rapidly compressing incident response and decision time for defenders. In an AI-accelerated threat environment, delayed exposure confirmation is operationally equivalent to having no early warning capability.	Expand incident response capacity to deal with surges in cyber incidents Implement automated IR playbooks that automate incident response for specific trigger conditions	<u>CSA / GovTech</u> • [CIID] Update incident reporting and response requirements in the CCoP to deal with increased speed and scale of AI-enabled threats • [NCIRC] Infuse AI into national IR capabilities (e.g. AI-assisted alert triage, automated threat hunt playbooks), and expand surge capacity and cross-sector coordination protocols for simultaneous AI-driven attacks on multiple CIIOs. <u>Sector Leads</u> • Work with CSA/ GovTech to expand CIIOs' threat detection and response capabilities • Develop sector IR playbook standards incorporating AI-speed response requirements. <u>CIIOs</u> • Implement automated IR playbooks (e.g. AI-assisted alert triage and pre-authorised automated containment actions) that execute in under 5 minutes without human approval for critical triggers. • Update incident reporting and response processes to accelerate response times and be able to handle simultaneous incidents

FOR DISCUSSION

 www.csa.gov.sg

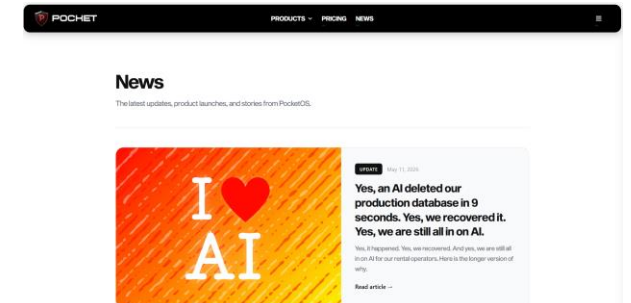
   CSAsingapore

As we adopt AI, we will also need to secure our use of AI. Enterprise level risks are getting more prevalent with increasing AI adoption

AI as an Attack Vector. At Vercel, attackers compromised Context.ai, a third-party AI tool connected to an employee's Google Workspace account via broad OAuth permissions, then hijacked the employee's session to access internal systems and environment variables. The incident highlighted how AI tools can become enterprise privilege concentrators, where a single compromised integration or stolen OAuth token can collapse multiple security boundaries across cloud, identity, and development environments.

AI vulnerability as a risk. AI vulnerability found in Cohere AI's Terrarium sandbox could allow attackers to escape the isolated execution environment and execute arbitrary code with root privileges on the host process. Because Terrarium is designed to run untrusted or AI-generated code, a successful sandbox escape could expose sensitive files, credentials, and connected services beyond the intended container boundary.

Over-privileged AI. A Claude-powered coding agent reportedly deleted PocketOS's production database and backups within seconds after obtaining access to an infrastructure token. The incident highlighted how AI agents with broad permissions can transform operational mistakes into enterprise-wide outages when connected directly to production infrastructure.



These recent developments favour the attackers more; more needs to be done by the defenders to address these concerns

- **Rapidly increasing AI adoption has led to a significantly wider attack surface across the AI ecosystem, not just the models themselves.** Attackers are increasingly targeting the surrounding AI ecosystem, including orchestration frameworks, developer tooling, communication protocols, browser interfaces, and enterprise integrations. **To mitigate this, organisations should consider adopting defence-in-depth measures across the full AI stack, including stronger dependency governance, secure configurations, segmentation, and continuous monitoring.**
- **Enterprise AI systems are becoming major privilege concentration points.** AI tools often aggregate access across cloud platforms, enterprise documents, APIs, and identity systems, allowing a single compromised integration or token to expose multiple connected environments. Traditional identity and access management models may also no longer be sufficient. **Enterprises should consider other approaches, such as approval gates for high-risk agent actions, and tighter separation between AI experimentation, development, and production environments.**
- **Agentic AI is shifting risk from passive exposure to active operational impact.** Modern AI agents can execute code, interact with tools, and take actions across enterprise systems with limited supervision. Recent incidents show that AI failures can now directly affect operational resilience and system integrity. **Organisations should consider sandboxing, execution boundaries, human-in-the-loop controls, action logging, and kill-switch mechanisms built into deployment architectures.**